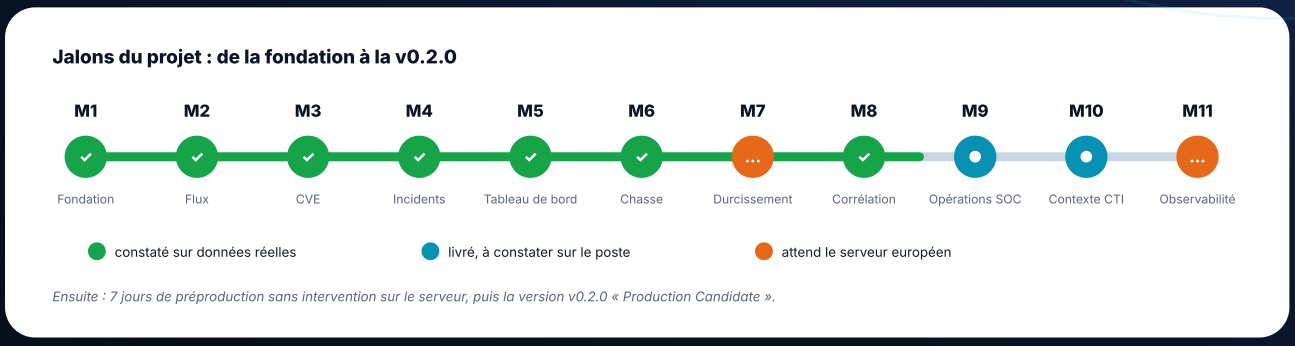
ILL Watch

FEUILLE DE ROUTE · VERSION 2.0

Jalons, critères et prochaines étapes

Où en est le projet, ce qui est constaté, ce qui est livré, ce qui reste à faire dans l'ordre jusqu'à la version 0.2.0, puis la suite.



VERSION
2.0 · édition du 10 novembre 2026

LOGICIEL
ILLWATCH 0.2.0.dev0

AUTEUR
Godwill FOKA · CyberillSec, une initiative CYBERILL

POUR QUI
Équipe projet, pilotage, contributeurs

Sommaire

1 1. Où en est le projet 1

2 2. Jalons M1 à M6 : la plateforme fonctionnelle

3 3. Jalons M7 à M11 : vers la v0.2.0

4 4. Ce qui reste à faire, dans l'ordre 6

5 5. Après la v0.2.0 7

6 6. Calendrier 8

Version en ligne, toujours à jour : https://godwillfoka.github.io/cyberillsec-illwatch/
Les numéros de page renvoient au pied de page du document.

Version du document	v2.0, mise à jour le 30 octobre 2026
Version du logiciel	`0.2.0.dev0` en cours sur `main` ; la dernière version publiée est `v0.1.1`, qui réunit les jalons M1 à M6
Prochain objectif	la v0.2.0, première version candidate à la production, puis la suite décrite plus bas

> **Notre règle**
>
> Un jalon n'est terminé que lorsque son résultat a été **vérifié**, pas lorsque le code est fusionné. Chaque jalon commence sur sa propre branche, se termine par un bilan écrit dans `Rapport/` et, quand il s'agit d'une version, par une étiquette dans le dépôt.

Jalons du projet : de la fondation à la v0.2.0



Ensuite : 7 jours de préproduction sans intervention sur le serveur, puis la version v0.2.0 « Production Candidate ».

1. Où en est le projet

En résumé : la plateforme fonctionne et a été vérifiée sur des données réelles. Les derniers jalons sont livrés dans le code ; il manque surtout un serveur en Europe pour les valider en conditions de production.

	Au 10 novembre 2026
Vérifié sur données réelles	les jalons M1 à M6 et M8 ; le scénario complet d'un SOC passe ses 48 contrôles sur le poste et ses 55 contrôles dans la vérification du lundi 9 novembre ; 528 453 indicateurs et 26 416 failles sur le poste de test
Livré, à vérifier sur le poste de test	M9 (opérations SOC), M10 (contexte des attaquants) et l'import de l'inventaire depuis Excel (ADR-028)
Livré, en attente du serveur européen	M7 (HTTPS sur un domaine public, note SSL Labs) et M11 (sept jours de préproduction)
Qualité	deux chaînes d'intégration continue (GitHub verte ; GitLab en échec d'exécution depuis le 30 octobre, voir l'étape 5), plus de 680 tests, environ 90 % du code couvert, une vérification sur données réelles chaque lundi, une préproduction et des captures d'écran refaites à chaque modification
Documentation	guide d'installation, manuel fonctionnel, cahier des charges, vision et feuille de route en version 2.0 ; 31 décisions d'architecture

Croissance de la base d'IOC sur le poste de travail



Le 06/10, les clés OTX, abuse.ch et TAXII ont été ajoutées ; le 08/10, l'historique OTX a été entièrement lu (334 311 IOC actifs).

2. Jalons M1 à M6 : la plateforme fonctionnelle

Ces six premiers jalons ont posé les fondations. Tous ont été vérifiés sur des données réelles.

Jalon	Ce qu'il apporte	Comment on sait qu'il est terminé	État
M1 Socle	configuration vérifiée, migrations, comptes, rôles, ligne de commande	la base, l'API, les rôles et l'audit fonctionnent	✅ vérifié
M2 Flux de menaces	cinq formats, neuf sources, dédoublonnage, origine des données, collecte automatique	au moins 500 indicateurs, trois sources en bonne santé, OTX et STIX connectés	✅ vérifié le 6 octobre
M3 Suivi des failles	base du NIST, catalogue KEV, EPSS, note composite, alertes	données NIST de moins de 24 heures, plus de 1 000 failles exploitées connues, EPSS sur plus de 90 % des failles	✅ vérifié le 6 octobre
M4 Incidents	six étapes selon le NIST, historique non modifiable	un incident mené jusqu'à sa clôture	✅ vérifié
M5 Tableau de bord	synthèse, activité, exports	le scénario SOC passe	✅ vérifié
M6 Chasse	six règles, sessions enregistrées	une chasse terminée avec des résultats	✅ vérifié (339 résultats en intégration continue)

La version `v0.1.1` a été publiée le 6 octobre 2026, avec son image Docker `ghcr.io/godwillfoka/cyberillsec-illwatch:0.1.1`.

3. Jalons M7 à M11 : vers la v0.2.0

Pour accepter la v0.2.0, nous rejouons un parcours complet, celui d'une vraie menace : une source publie un renseignement, ILLWATCH le collecte, le nettoie, l'enrichit, le compare au parc, lève une alerte, ouvre un incident ; l'analyste enquête, cherche des traces, consulte le contexte ATT&CK, suit le tableau de bord, résout l'incident, et tout reste inscrit dans l'audit. Ce parcours est automatisé par `scripts/scenario_soc.py` et rejoué à chaque modification.

M7 : Durcissement de production

L'objectif : pouvoir déployer ILLWATCH sans aucune réserve de sécurité connue.

Lot	Ce qu'il contient	État
1	audit en ajout seulement, sonde `/ready`, en-têtes HTTP de sécurité, identifiant de requête, blocage par compte et par adresse, sauvegarde et restauration	✅ vérifié le 3 octobre
2	rôles PostgreSQL séparés, Redis protégé par mot de passe, changement de clé sans coupure, sessions révocables	✅ vérifié le 4 octobre
3	HTTPS avec Caddy, analyse de l'image Docker, migrations dans un conteneur temporaire, entretien quotidien	✅ HTTPS vérifié en local ; le script de déploiement `deploy-vps.sh` est prêt
Interface (ADR-016)	douze écrans en temps réel, identité visuelle ILLWATCH, cinq langues	✅ utilisée sur données réelles
Inventaire en fichier (ADR-028)	import et export Excel ou CSV, aperçu, import seulement si tout est correct	🟢 livré le 30 octobre
Écriture	plus aucun tiret long, avec un contrôle automatique	🟢 livré le 30 octobre

Pour clore M7 : faire tourner la pile de production sur un serveur européen et obtenir au moins la note A chez SSL Labs (workflow « Clôture M7 »). **Ce qui manque :** louer le serveur et le nom de domaine.

M8 : Détection et corrélation

Ce jalon a appris à ILLWATCH à parler de **votre** parc : note de confiance de chaque indicateur (ADR-017), localisation des adresses IP sans service extérieur (ADR-019), inventaire et règles de corrélation CORR-01 à CORR-03 (ADR-020), comparaison des versions (ADR-021), plages réseau, plateforme de l'équipement, et réglage de la détection des domaines générés par algorithme à partir de la liste Tranco des sites les plus visités.

Pour le clore : détecter 100 % des cas attendus sur un jeu de test figé et publier le taux de faux positifs. ✅ **Terminé le 14 octobre 2026** : 100 % des cas détectés, 0 % de faux positifs. Sur les données réelles, la première passe avait levé 38 évènements ; la comparaison des versions en a écarté 37 à juste titre.

M9 : Opérations SOC

Trois niveaux d'analystes et l'escalade de l'un à l'autre, une liste d'exclusion pour les faux positifs, la chasse lancée depuis un incident, des recommandations de réponse, des règles versionnées et l'écran Pilotage (ADR-022).

Pour le clore : qu'un incident passe du niveau 1 au niveau 3 sans quitter ILLWATCH, avec son délai de résolution mesuré. 🟢 **Vérifié en intégration continue** ; reste à le rejouer sur le poste de test.

M10 : Contexte des attaquants

Le référentiel MITRE ATT&CK (ADR-023), les campagnes et leur attribution à partir de l'infrastructure (ADR-024), l'export STIX 2.1 et le serveur TAXII 2.1 (ADR-025).

Pour le clore : qu'une alerte affiche sa technique ATT&CK et, quand on le connaît, l'acteur. 🟢 **Vérifié en intégration continue** ; reste à le vérifier sur le poste après `illwatch attack import`.

M11 : Supervision et déploiement

La route `/metrics`, Prometheus et Grafana (dix alertes, deux tableaux de bord), le test d'acceptation sur un jeu figé, une restauration testée chaque mois et trois environnements : développement, préproduction et production (ADR-026).

Pour le clore : sept jours de collecte continue en préproduction sans aucune intervention, des tableaux complets et une restauration réussie. **Ce qui manque :** ces sept jours, sur le serveur prévu pour M7.

4. Ce qui reste à faire, dans l'ordre

#	Tâche	Qui	Après	Temps estimé
1	Mettre à jour le poste de test : `git pull`, `pip install -c constraints.txt -e ".[dev]"`, `illwatch db upgrade`, `./scripts/build-web.sh`, `illwatch attack import`, puis redémarrer l'API et le worker	porteur du projet		30 min
2	Déclarer l'inventaire réel avec le modèle Excel, puis lancer `illwatch cves refresh-affected` et `illwatch correlate run`	porteur du projet	1	1 à 2 h
3	Vérifier M9 (escalade du niveau 1 au niveau 3, écran Pilotage) et M10 (ATT&CK, campagne, `curl /taxii2/`) sur le poste, puis écrire les bilans	porteur du projet	1	2 h
4	Suspendre la source RedEye tant que son serveur ne répond pas ; régler le fuseau horaire de la machine virtuelle	porteur du projet		15 min
5	Rétablir le pipeline GitLab en échec depuis le 30 octobre (vérifier les minutes de calcul et les exécuteurs dans les quotas d'utilisation), le relancer, puis traiter les mises à jour Dependabot	porteur du projet		30 min
6	Louer un serveur européen (2 cœurs, 4 Go, 40 Go) et un nom de domaine, lancer `deploy-vps.sh install`, inscrire le domaine dans `deploy/vps-domaine.txt`	porteur du projet		2 h
7	Laisser le workflow « Clôture M7 » mesurer la note TLS : **M7 terminé**	intégration continue	6	automatique
8	Sept jours de préproduction sans intervention et la restauration du mois : **M11 terminé**	serveur	6	7 jours
9	Étiqueter `v0.2.0`, publier la version et son image	porteur du projet	7 et 8	1 h

Les demandes de fusion du 30 octobre 2026 (inventaire Excel, documentation v2, qualité des alertes, priorisation expliquée, transparence du renseignement) sont toutes fusionnées.

5. Après la v0.2.0

Une revue d'amélioration du 30 octobre 2026 a déplacé l'accent : avant d'ajouter des modules, rendre les résultats plus dignes de confiance et plus utiles au quotidien. Les trois premières priorités sont déjà livrées :

Amélioration	Décision	État
Mesurer la qualité des alertes en situation réelle, par règle et par source	ADR-029	🟢 livré le 30 octobre, à mesurer après un mois d'exploitation réelle
Expliquer la priorisation : criticité, exposition, exploitation, version, échéance	ADR-030	🟢 livré le 30 octobre
Rendre visibles la source, la fraîcheur et la confiance de chaque donnée	ADR-031	🟢 livré le 30 octobre

Restent, dans cet ordre, avec les thèmes du tableau suivant :

Thème	Ce que nous voulons faire	Priorité
Pilote avec des analystes SOC	les observer traiter une alerte, ouvrir un incident, justifier un faux positif, préparer un rapport ; corriger les frictions observées	haute
Accessibilité de l'application	contrôle WCAG automatisé de l'interface SOC en CI, comme pour le site de présentation, et parcours au clavier et au lecteur d'écran	haute
Plusieurs organisations et connexion unique	servir plusieurs organisations depuis une même instance, avec OIDC	haute
Cyberill TI Cloud	une offre hébergée dans l'Union européenne	haute
Assistant d'analyse	un modèle de langage pour lire les bulletins et les incidents	moyenne
Connecteurs de parc	remplir l'inventaire depuis GLPI ou une CMDB	moyenne
Règles Sigma	les importer depuis des collections TAXII	moyenne
Type de faille (CWE) dans la note	une décision à écrire, avec de nouveaux poids	basse
Site de présentation	relecture par des locuteurs natifs des cinq langues, mentions légales, hébergement à côté de l'application	moyenne

6. Calendrier

Période	Ce qui s'est passé, ou ce qui est prévu
juillet à septembre 2026	cadrage, cahier des charges, jalons M1 à M6
du 3 au 6 octobre 2026	audit complet, les trois lots de M7, version `v0.1.1`, M2 et M3 vérifiés
8 octobre 2026	SENTRY devient ILLWATCH
du 10 au 15 octobre 2026	interface web, M8 terminé, M9, M10 et M11 livrés
du 22 au 24 octobre 2026	site de présentation en cinq langues, demandes de démonstration
30 octobre 2026	inventaire en fichier, nouvelle ponctuation, documentation v2.0
novembre 2026 (objectif)	serveur européen, M7 et M11 terminés, version `v0.2.0`